

Graph Admin

Bối cảnh (Context)

Theo xu hướng hiện đại, công ty đã đập bỏ toàn bộ REST API cũ để chuyển sang sử dụng GraphQL, một truy vấn dữ liệu linh hoạt giúp Frontend gọi bao nhiêu dữ liệu tùy thích.

Dev Lead khẳng định: "GraphQL chỉ là cầu nối dữ liệu, không có REST Endpoint nào để hacker mò mẫm nữa". Nhưng họ đã để quên một tính năng cực kỳ thân thiện với nhà phát triển tên là "Introspection", và quên kiểm tra quyền truy cập ở các Query nhạy cảm.

Mục tiêu (Objective)

- **Nhiệm vụ:** Tìm ra cấu trúc dữ liệu bí mật mà GraphQL đang quản lý và truy vấn mật khẩu hoặc dữ liệu ẩn của Admin.
- **Vấn đề / Lỗ hổng: GraphQL Introspection & Insecure Authorization.** Tính năng Introspection (Tự kiểm tra) của GraphQL cho phép khách vãng lai hỏi xin toàn bộ danh sách Schema (các Query, Mutation, Kiểu dữ liệu). Sau khi có Schema, kẻ tấn công dễ dàng thấy các Query ẩn (ví dụ: `getAllUsers` , `getAdminSecret`) và gọi chúng.
- **Flag:** Truy vấn thành công dữ liệu nhạy cảm qua endpoint của GraphQL.

Gợi ý (Hints)

- Gửi một truy vấn `__schema` (Introspection Query) để xem toàn bộ sơ đồ cấu trúc của API.
- Sử dụng công cụ GraphQL Voyager hoặc InQL trong Burp Suite để trực quan hóa schema.
- Dựng lại câu Query nhạy cảm và gửi yêu cầu lấy Flag.